Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 El costo real de la inseguridad

1.4 **El SDLC tradicional y la seguridad tardía**

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 CAMS: Culture y Automation

1.8 CAMS: Mesurement y Sharing

1.9 La seguridad como proceso continuo



1.4 El SDLC tradicional y la seguridad tardía

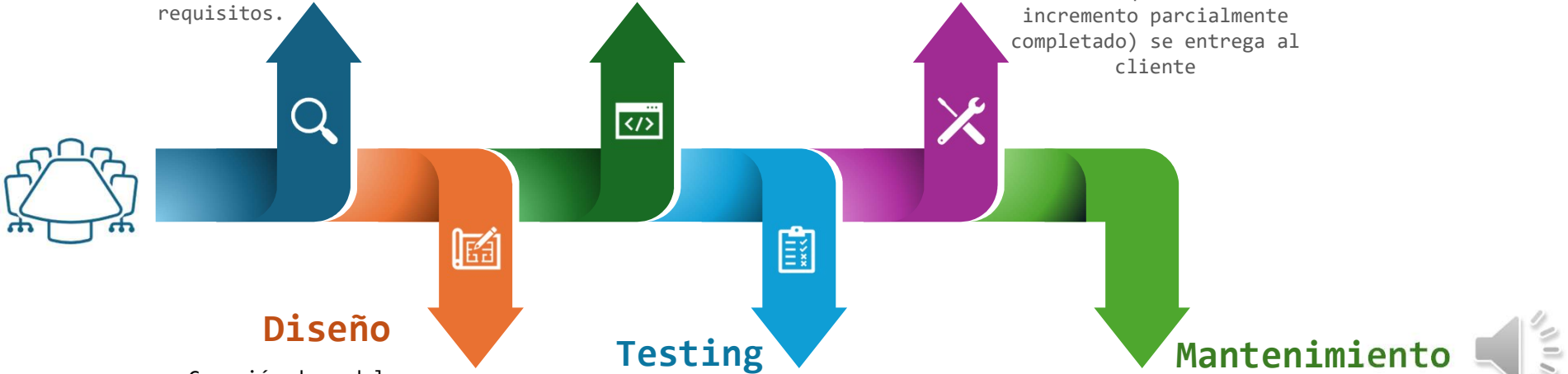
FADENA

- ¿Qué es el SDLC?
- Modelos de Proceso de Software
- Solucionando la seguridad tardía
- El mito del test de penetración al final
- Shift Left
- Gestionando la seguridad del software



1.4 El SDLC tradicional y la seguridad tardía

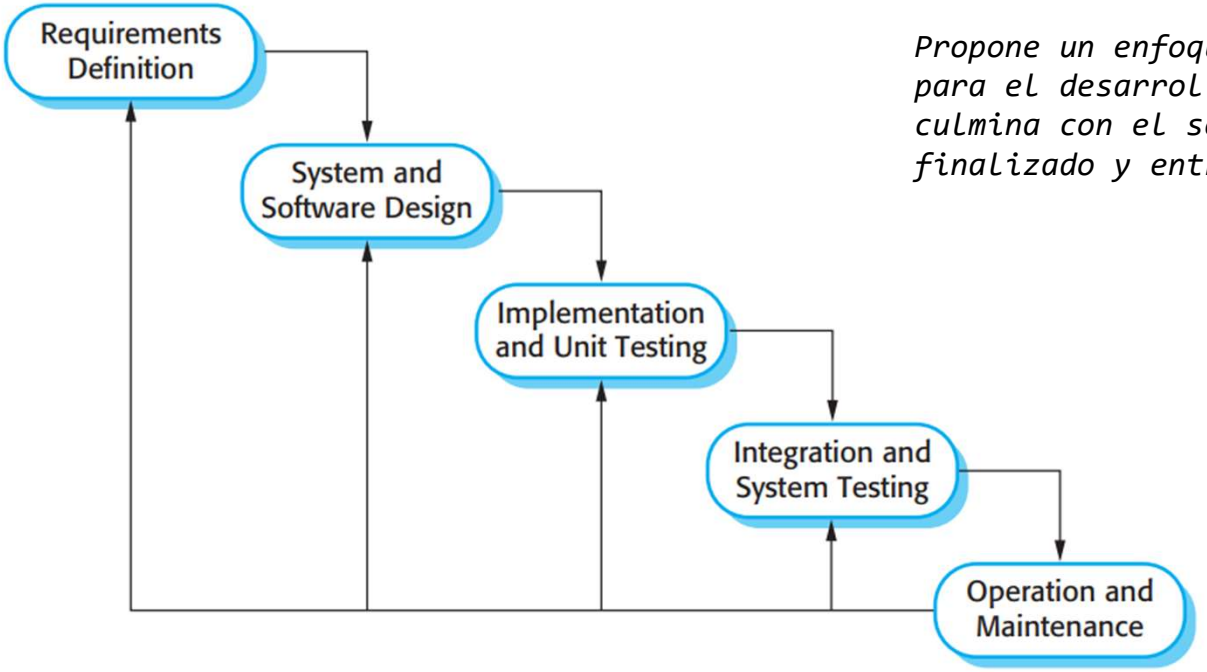
¿Qué es el SDLC?



1.4 El SDLC tradicional y la seguridad tardía

Modelos de Proceso de Software

Waterfall



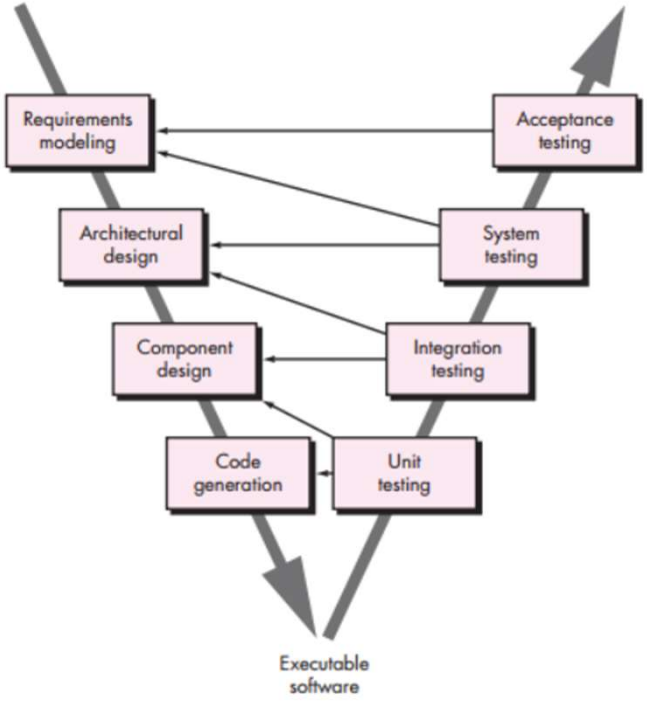
Propone un enfoque sistemático y secuencial para el desarrollo del software, cuyo proceso culmina con el soporte del software finalizado y entregado.

1.4 El SDLC tradicional y la seguridad tardía

Modelos de Proceso de Software

Modelo V

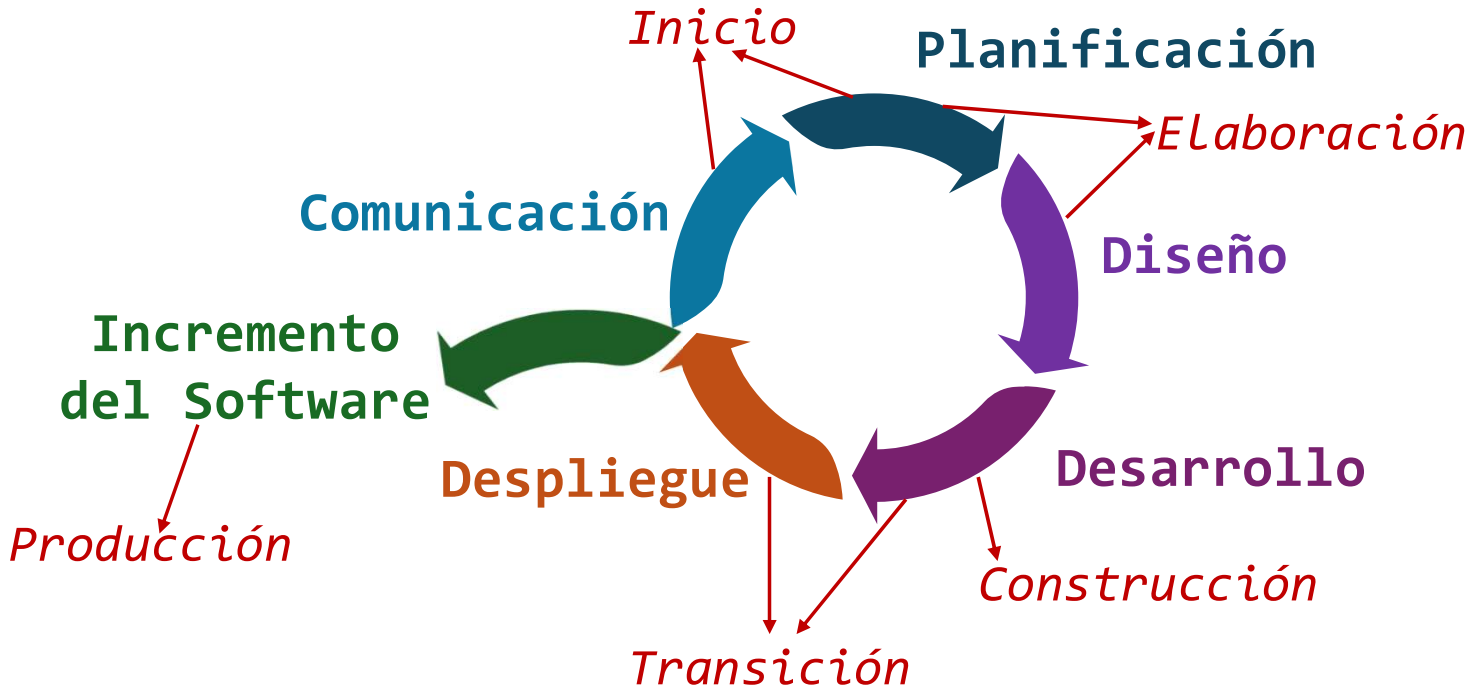
El modelo V describe la relación entre las acciones de aseguramiento de la calidad y las acciones asociadas con la comunicación, el modelado y las actividades iniciales de construcción. A medida que un equipo de software avanza por el lado izquierdo de la V, los requisitos básicos del problema se refinan en representaciones cada vez más detalladas y técnicas del problema y su solución.



1.4 El SDLC tradicional y la seguridad tardía

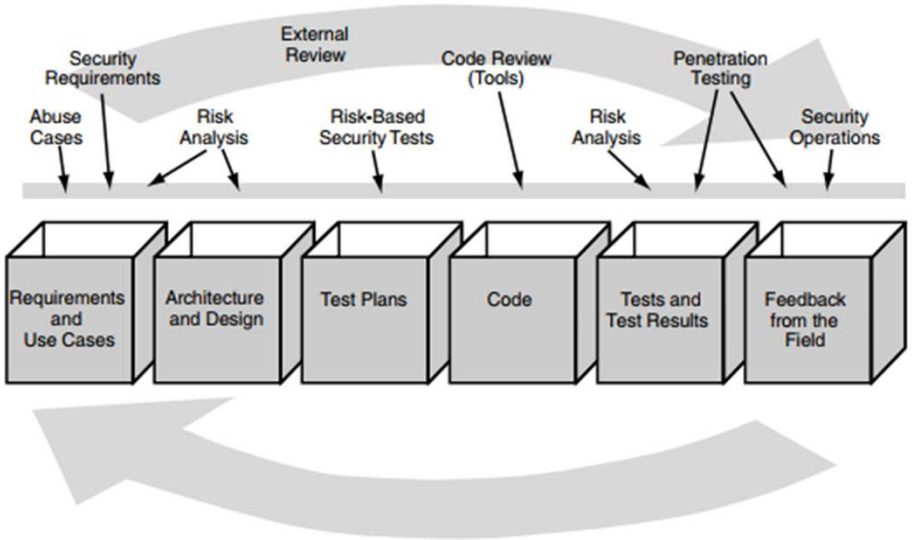
Modelos de Proceso de Software

Iterativo Incremental



1.4 El SDLC tradicional y la seguridad tardía

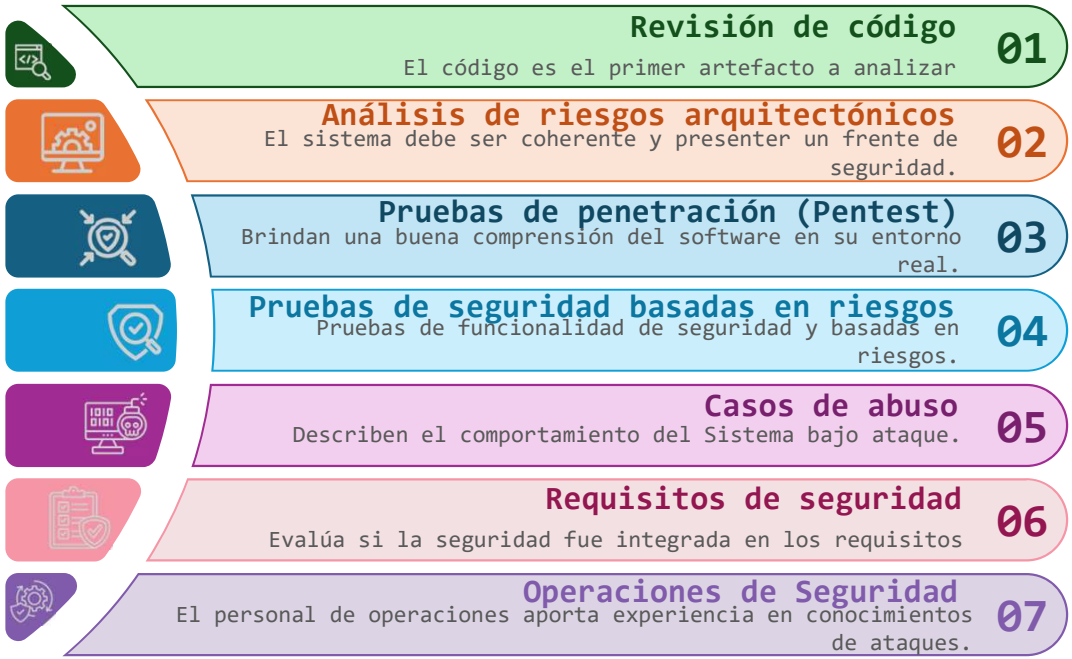
Solucionando la seguridad tardía



- Revisión de código 01
- Análisis de riesgos arquitectónicos 02
- Pentest 03
- Pruebas de seguridad basadas en riesgos 04
- Casos de abuso 05
- Requisitos de seguridad 06
- Operaciones de Seguridad 07

1.4 El SDLC tradicional y la seguridad tardía

Solucionando la seguridad tardía



1.4 El SDLC tradicional y la seguridad tardía

El mito del test de penetración al final

Enfoque reactivo

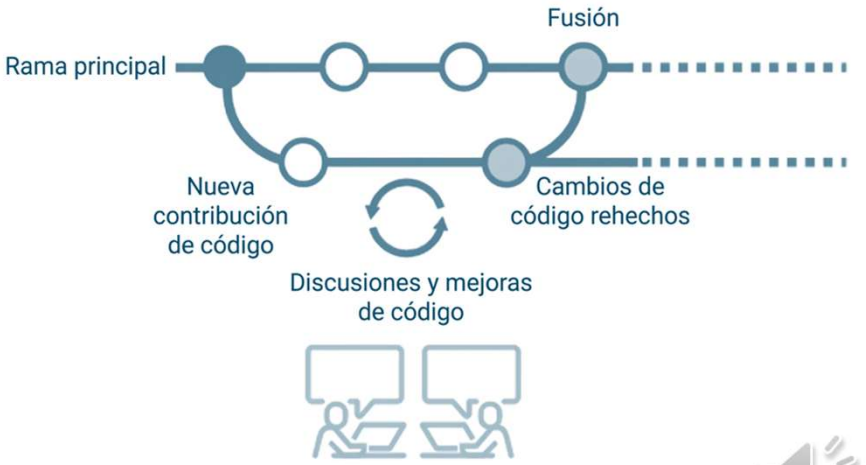
Contratar pruebas de penetración solo al final actúa como una solución superficial de "penetración y parcheo".

Limitación técnica

Funciona para ajustar el entorno (firewalls o parches de SO), pero no resuelve fallos lógicos internos.

Fallos estructurales

Los problemas de arquitectura no se solucionan eficazmente cuando el código ya está en producción.



1.4 El SDLC tradicional y la seguridad tardía

Shift Left

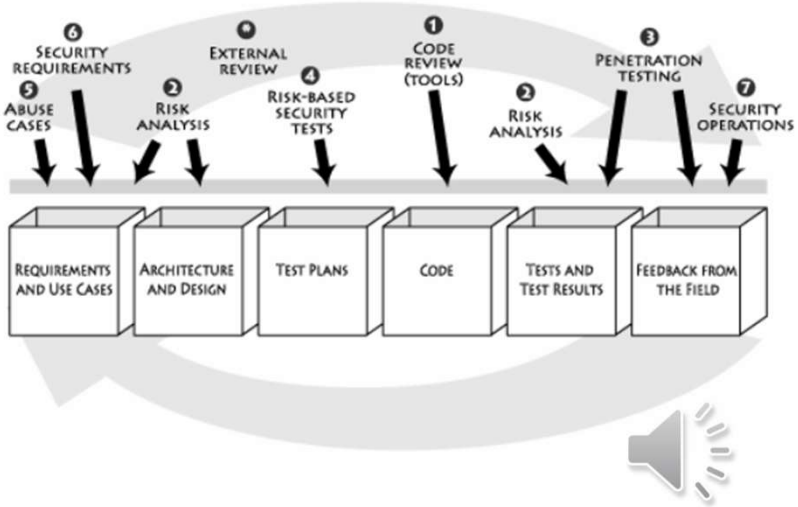
Desplazamiento a la Izquierda
Mover los controles de seguridad hacia las fases iniciales del desarrollo (Requisitos, Arquitectura y Código)

Revisión Automatizada de Código
Implementar de manera constante herramientas en el desarrollo para mitigar hasta el 50% de las vulnerabilidades.

Análisis de Riesgos Arquitectónicos
Evaluar y modelar amenazas en el diseño estructural antes de escribir código.

Requisitos de Seguridad y Casos de Abuso
Incorporar escenarios de ataque y criterios de seguridad desde la concepción del producto.

Combinación de Puntos de Contacto
Unir revisiones de código, evaluaciones de arquitectura y pruebas prácticas para lograr una cobertura integral



1.4 El SDLC tradicional y la seguridad tardía

Gestionando la seguridad del software

Lograr un nivel adecuado de seguridad de software implica más que cumplir con las regulaciones o implementar las mejores prácticas comúnmente aceptadas.



1.4 El SDLC tradicional y la seguridad tardía

Gestionando la seguridad del software

Dimensiones	Preguntas	Propósito del Negocio
Protección de valor y activos	¿Qué valor central buscamos proteger? ¿Qué activos específicos lo sostienen, por qué debemos resguardarlos y qué ocurriría si se comprometen?	Asegurar la continuidad y valor central del negocio.
Prevención de costos	¿Qué escenarios adversos debemos prevenir, a qué costo y cuál es el nivel de interrupción operativa que la empresa puede tolerar antes de actuar?	Optimizar el presupuesto de mitigación eficientemente.
Tolerancia operativa	¿Cómo medimos y controlamos el riesgo que persiste tras implementar las medidas de mitigación?	Establecer planes de respuesta.
Riesgo residual	¿Cómo monitoreamos el riesgo restante tras mitigar?	Gobernanza continua y actualización de controles.